

Region of Southern Denmark's Intended Use of Microsoft 365

Date: 15-02-2024

Decision

Public Authorities

Response to Inquiry

Legal Basis for Processing

Data Processor

Transfer to Third Countries

Based on a specific inquiry from the Region of Southern Denmark in a current case, the Data Protection Agency has considered the extent to which the so-called Chromebook case is relevant for the procurement and use of other cloud services. Specifically, for the Region of Southern Denmark, this concerns the region's intended migration to Microsoft 365.

Journal Number: 2023-431-0012

Summary

Shortly after the publication of the Data Protection Agency's decision of January 30, 2024, in the so-called Chromebook case, the Region of Southern Denmark contacted the Data Protection Agency with two questions raised by the case regarding the region's own intended migration to Microsoft 365. It is the Data Protection Agency's immediate perception—based on the material that the region has submitted to the Agency—that there is a corresponding issue regarding the transfer of personal data to the cloud service provider—in this case, Microsoft—for its own purposes, which the region must address.

In this connection, the Data Protection Agency points out a number of specific matters that the Region of Southern Denmark must map, clarify, and assess.

The response to the Region of Southern Denmark occurs as part of an ongoing case but highlights, in the Agency's view, a number of fundamental questions that have been raised generally as a result of the Chromebook case. Therefore, the Data Protection Agency exceptionally chooses to publish the Agency's response to the region.

Statement

1. Inquiry

The Data Protection Agency became aware in mid-2022 that the Region of Southern Denmark had initiated a migration of several IT systems to operate using cloud services. This specifically involved migration from the region's on-premise Microsoft Office solution to a cloud-based Microsoft 365 solution (hereinafter M365).

In this regard, the Data Protection Agency decided on its own initiative to investigate the Region of Southern Denmark's compliance with data protection regulations regarding the migration to M365 in more detail.

Most recently, on February 5, 2024, the Region of Southern Denmark contacted the Data Protection Agency in the matter with the following questions:

“[The Chromebook decision] initially raises two fundamental questions regarding the Region of Southern Denmark's intended migration to M365:

In the Chromebook case, it is primarily children's information that is processed. With the purpose of use that the Region of Southern Denmark has described according to the previous dialogue, will we then see a corresponding prohibition regarding the use of Microsoft as a data processor concerning the issue of legal basis for the transfer of information for the maintenance of services?

From the Chromebook case, it is stated, among other things, that ‘the functionality of the solutions that are desired to be used, or the market position of the supplier that is desired to be chosen, cannot justify a lack of compliance with data protection regulations. A standardized structure of the solutions or the mere use of a standard product cannot justify a lack of compliance with data protection regulations’ – could this in itself give rise to an injunction?”

2. Response

The Data Protection Agency has, on January 30, 2024, in the so-called Chromebook case, made a

decision regarding the question of the extent to which a number of municipalities have the legal basis to transfer personal data to a cloud service provider for the purposes of (i) delivery and (ii) improvement of the provided services as well as (iii) development of new features and services. The conclusion in the Data Protection Agency's decision is that there is a legal basis for transferring students' information for the purpose of delivering the services, improving the security and reliability of the services, communicating with, among others, the municipalities, and complying with legal obligations.

However, it is also the Data Protection Agency's assessment that the Folkeskole Act does not sufficiently clearly authorize the municipalities to transfer students' information for the maintenance and improvement of the Google Workspace for Education service, ChromeOS, and the Chrome browser, or for measuring performance and developing new features and services in ChromeOS and the Chrome browser.

As also indicated in the Chromebook case, a fundamental prerequisite for the lawful processing of personal data is that the data controller—in this case, the Region of Southern Denmark—has knowledge of and has mapped which personal data is processed and for what purpose(s). This includes, among other things, an investigation of whether the cloud service provider—in this case, Microsoft—processes the personal data entrusted to it for its own purposes. If so, the region must assess whether the information can be transferred to the provider, and if so, on what legal basis. On July 3, 2023, the Region of Southern Denmark submitted a number of documents that further explain the region's assessment of various data protection legal issues regarding the use of selected products and services in the M365 solution. These documents include, among other things, overarching descriptions of which personal data...

the region is expected to be processed as part of the region's use of M365. Overall, Region Southern Denmark has stated that the M365 solution will be used both in administration and in the healthcare sector. The solution will thus be used by, among others, management, administrative staff, clinical administrative personnel, doctors, nurses, and other staff. Specifically, the solution will be used, among other things, to send and receive emails, manage documents and other information, store files and documents, facilitate audio and video communication between employees, create documents and presentations, and similar tasks. The documents, communications, etc. will content-wise include information about, among others, the employees themselves and patients in Region Southern Denmark.

Furthermore, the Data Protection Agency is not clear on the extent to which metadata regarding the region's employees' use of the M365 solution will be processed. This may include, for example, information about product and service settings, information about the use of the tools, etc. If this is the case, such metadata – depending on the circumstances – may also include information about patients, etc. This could be the case if information about patients appears in file names or otherwise forms part of the metadata.

Among the documents that the region submitted on July 3, 2023, are also Microsoft's contractual terms for the provision of M365, including the data processing agreement. The data processing agreement "Supplement on Data Protection for Microsoft Products and Services, Last updated January 1, 2023" states, among other things, the following: "Nature of Data Processing; Ownership - Microsoft will only use and otherwise process Customer Data, Data from Professional Services, and Personal Data in accordance with the Customer's documented instructions and as described in and subject to the limitations set forth below, (a) to provide the Products and Services to the Customer in accordance with the Customer's documented instructions and (b) in connection with business activities related to the delivery of the Products and Services to the Customer. [...]"

Processing to deliver the Products and Services to the Customer - Regarding the purposes of this Supplement on Data Protection, the term "deliver" a "Product" consists of the following: Delivery of functionalities as licensed, configured, and used by the Customer and its users, including the delivery of customized user experiences; Troubleshooting (preventing, detecting, and remedying issues); and Keeping products updated and performing, as well as improving users' productivity, reliability,

efficiency, quality, and security. [...] In each case, the delivery of the Products and Services occurs with respect to security obligations in accordance with Data Protection Requirements.

Microsoft will not use or otherwise process Customer Data, Data from Professional Services, or Personal Data in the delivery of Products and Services in connection with: (a) user profiling, (b) advertising or similar commercial purposes, or (c) market research aimed at creating new features, services, or products or any other purpose, unless such use or processing is in accordance with the Customer's documented instructions.

Microsoft's processing for business activities related to the delivery of the Products and Services to the Customer - Regarding this Supplement on Data Protection, "business activities" means the processing activities approved by the Customer in this section. The Customer authorizes Microsoft to: create aggregated statistical, non-Personal Data from data that contains pseudonymized IDs (e.g., usage logs that contain unique, pseudonymized IDs) and calculate statistics related to Customer Data or Data from Professional Services in each case without accessing or analyzing the content of Customer Data or Data from Professional Services and limited to achieving the purposes set forth below, each in connection with the delivery of the Products and Services to the Customer. These purposes are: billing and office administration, compensation (e.g., calculation of employee commissions and partner incentives), internal reporting and business modeling (e.g., preparing forecasts, revenue, capacity planning, and product strategy), and financial reporting.

Microsoft will apply the principles of data minimization and will not use or otherwise process Customer Data, Data from Professional Services, or Personal Data concerning: (a) user profiling, (b) advertising or similar commercial purposes, or (c) any other purposes except in connection with the purposes specified in this section. Furthermore, and as it pertains to all processing in this Supplement on Data Protection, Microsoft's processing of business activities remains subject to Microsoft's confidentiality obligations and the terms regarding Disclosure of processed data. [...]

Processing of Personal Data, GDPR - All Personal Data processed by Microsoft in connection with the delivery of the Products and Services is provided as part of either (a) Customer Data, (b) Data from Professional Services, or (c) data that is generated, derived, or collected by...

Microsoft, including data sent to Microsoft as a result of a Customer's use of service-based features or collected by Microsoft from locally installed software. Personal data provided to Microsoft by, or on behalf of, the Customer through the use of the Online Service is also Customer Data. Personal data provided to Microsoft by, or on behalf of, the Customer through the use of Professional Services is also Data from Professional Services. Pseudonymized identifiers may be included in data processed by Microsoft in connection with the delivery of the Products and are also Personal Data. Any Personal Data that is pseudonymized or has had its identification removed, but is not anonymized, or Personal Data that is derived from Personal Data, is also Personal Data. To the extent that Microsoft is a processor or sub-processor of Personal Data under the GDPR, the Terms in GDPR in Appendix 1 govern, and the text in the subsection ("Processing of Personal Data, GDPR") shall be considered supplementary:

Roles and Responsibilities of Data Processors and Data Controllers

Customers and Microsoft agree that the Customer is the data controller for Personal Data, and Microsoft is the data processor of such data, except (a) when the Customer acts as a processor of Personal Data, in which case Microsoft is a sub-processor, or (b) if otherwise stated in the specific terms for the Products or this Appendix on data protection. When Microsoft acts as a data processor or sub-processor of Personal Data, Microsoft processes Personal Data only in accordance with documented instructions from the Customer. The Customer agrees that the Customer Agreement (including the terms of the Appendix on data protection and relevant updates) together with the product documentation and the Customer's use and configuration of features in the Products are the Customer's complete and final documented instructions to Microsoft regarding the processing of Personal Data or the documentation for the Professional Services and the Customer's use of Professional Services. Information about the use and configuration of the Products can be found at <https://docs.microsoft.com> (or on a subsequent website) or in another agreement that incorporates this

Appendix on data protection. Any additional or modified instructions must be agreed upon in accordance with the change process for the Customer's agreement. In the event that the Data Protection Regulation applies, and the Customer is a processor, the Customer warrants to Microsoft that the Customer's instructions, including the appointment of Microsoft as a processor or sub-processor, are approved by the relevant data controller.

To the extent that Microsoft uses or otherwise processes Personal Data under the GDPR for business activities related to the delivery of the Products and Services to the Customer, Microsoft complies with the obligations imposed on an independent data controller under the GDPR for such use. Microsoft accepts the additional responsibilities that come with being a "data controller" under the GDPR for such processing, to: (a) act in accordance with applicable legal requirements to the extent required under the GDPR, and (b) ensure increased transparency for Customers and confirm Microsoft's accountability in connection with this data processing. Microsoft employs security measures to protect Customer Data, Data from Professional Services, and Personal Data during such processing, including those identified in this Appendix on data protection and those mentioned in Article 6, Paragraph 4, of the GDPR. With respect to the processing of Personal Data under this section, Microsoft undertakes the obligations set forth in Appendix C – Additional Security Measures, whereby (i) any disclosure by Microsoft of Personal Data, as described in Appendix C – Additional Security Measures, that has been transferred in connection with business activities, is considered a "Relevant Disclosure" and (ii) the obligations in Appendix C – Additional Security Measures apply to such Personal Data."

Based on the above, the Data Protection Authority understands that Microsoft, as part of Region Southern Denmark's potential use of M365, will process certain personal data about the region's employees and possibly patients in the region. Microsoft will process this information (i) to deliver the service and (ii) for business activities in connection with the delivery of the service. According to the data processing agreement, the delivery of the service consists of (i) providing functionality, including delivering customized user experiences, (ii) troubleshooting, and (iii) updating products as well as improving users' productivity, reliability, efficiency, quality, and security.

Furthermore, Microsoft's business activities consist of (i) billing and account management, (ii) payroll, (iii) internal reporting and business modeling, and (iv) financial reporting. It is indicated that processing for these purposes will occur based on aggregated statistical (anonymized) information generated from pseudonymized information. The Data Protection Authority further understands that Microsoft will not process personal data that the company will receive from the region for (i) user profiling, (ii) advertising or similar, and (iii) market research aimed at creating new features, services, or products (or other purposes).

However, the precise scope of the aforementioned data processing is not clear to the Data Protection Authority. Fundamentally, it is the Data Protection Authority's view that public authorities have a certain access to disclose personal data to IT providers for the provider's own purposes. This may include, among other things, the delivery of the service, improving the security and reliability of the service, ****Compliance with Legal Obligations, etc.****

However, it depends on an assessment of the legal basis that justifies or obligates the authority to perform its tasks, precisely to what extent the authority can disclose personal data to the supplier. The assessment also includes which information will be disclosed.

Furthermore, data protection regulations do not prevent the disclosure of anonymized information. This is because anonymized information is not covered by data protection regulations. Similarly, personal data can always be lawfully anonymized so that the anonymized information can be reused.

In the context of the provision of cloud services, it is crucial when the personal data is anonymized. There will not be a disclosure of personal data if the information is anonymized locally, after which only the anonymized information is disclosed to the supplier. The situation is different if personal data is collected and disclosed to the supplier, after which the supplier, as an independent data controller, chooses to anonymize the information. In the latter case, it is a matter of disclosing personal data.

Based on the material that Region Southern Denmark has preliminarily submitted, it is the Data Protection Authority's immediate impression that there is a corresponding issue regarding the disclosure of personal data to the cloud service provider for its own purposes, which the region must address concerning the region's intended use of Microsoft 365.

Region Southern Denmark must therefore – as also stated in the Data Protection Authority's email of January 12, 2024 – map, clarify, and assess:

1. Which categories of individuals will the region process personal data about, including, for example, employees, patients, etc., as part of the use of M365?
2. What personal data will the region process about these categories of individuals, and to what extent will metadata about these individuals be collected and processed?
3. What legal basis will underpin the region's processing of the relevant personal data?
4. For what specific purposes will Microsoft specifically process information in connection with keeping "products updated and performing, as well as improving users' productivity, reliability, efficiency, quality, and security," and in what role?
5. How is the aforementioned aggregated statistics generated specifically, including particularly whether the aggregation or anonymization occurs before the information is disclosed to Microsoft?
6. Will the relevant legal basis be able to underpin the disclosure of the relevant personal data to Microsoft for the purposes described above?

The Data Protection Authority notes that it is Region Southern Denmark that has the responsibility to carry out the aforementioned mapping, clarification, and assessment. This follows from Article 24, paragraph 1, and Article 5, paragraph 2 of the Data Protection Regulation.

The Data Protection Authority is, of course, available and can advise and guide on the obligations arising from data protection regulations, including possibly providing an opinion on the extent to which a processing activity can occur within the framework of data protection regulations. However, this requires a greater knowledge of the circumstances that the authority must assess. In this case, it concerns a more comprehensive mapping of data flows.

In conclusion, the Data Protection Authority notes that in the so-called Chromebook case, the authority has stated that the functionality of the solutions that are desired to be used, or the market position of the supplier that is desired to be chosen, cannot justify a lack of compliance with data protection regulations. A standardized structure of the solutions or the mere use of a standard product cannot justify a lack of compliance with data protection regulations either. Data protection regulations do not, of course, prevent the use of standardized solutions or solutions from specific suppliers.

However, it follows from Article 5, paragraph 2 of the Regulation that the data controller is responsible for and must be able to demonstrate, among other things, that personal data is processed lawfully, fairly, and transparently. This obligation applies regardless of whether the data controller chooses to use standardized or tailored solutions, and it is the data controller who is responsible for ensuring that the solutions that the data controller decides to use comply with data protection regulations.

****3. Concluding Remarks****

The Data Protection Authority notes that the above is the authority's immediate assessment, which is based on the circumstances and information that Region Southern Denmark has submitted. The Data Protection Authority cannot exclude that there are circumstances that the authority has not taken into account, which may entail a different assessment.

[1] Region Southern Denmark has specified in an email dated February 21, 2024, that more specifically, the region has initiated analyses regarding the conditions surrounding the use of cloud and has not yet initiated a concrete migration to Microsoft 365.

[2] Data Protection Authority's guidance on cloud, March 2022, p. 8 (example 3), p. 10, and p. 12-14.